

Técnicas e Ferramentas para Auditoria de Sistemas

segunda-feira, 13 de abril de 2026 09:55

Introdução às técnicas e tipos de ferramentas para auditoria de sistemas

Para alguns autores como Beneton (2017) e Kamal(2020) e o ISACA (2016, 2017), as técnicas e ferramentas envolvem 3 tipos distintos: a interação com pessoas; a análise manual e a análise técnica.

Para interação com pessoas, temos:

- **Entrevistas:** interagir com membros da equipe para entender processos, procedimentos e desafios para a auditoria.
- **Questionários:** questionários a serem respondidos pelos profissionais de áreas-chave.
- **Pesquisas:** obtenção de dados via pesquisas individuais ou para grupos.
- **Perguntas e observação:** conversas e observações no contexto do cotidiano da empresa.
- **Dinâmicas em grupo:** exercícios ou atividades especializadas direcionadas a grupos.

Para a análise manual, temos:

- Análise e revisão de documentação, analisar documentos, como políticas de segurança, procedimentos operacionais e registros de auditoria.
- Análise de configurações.
- Desenho de fluxos para documentar processos de negócios e controles automatizados.
- Simulação de mesa.
- Revisões gerenciais.
- Autoavaliação.
- Análise de código.

Para a análise técnica com uso de ferramentas, que é um dos principais métodos que exigem um conhecimento técnico amplo dos auditores, temos:

- **Planilhas eletrônicas:** organização e análise obtida de diferentes fontes.
- **Scripts:** execução automatizada para obtenção ou filtragem de dados específicos.
- **Software de auditoria:** para analisar o conteúdo de arquivos de dados, como os logs de sistemas, lista de acesso de usuários.
- **Ferramentas/software de auditoria específicas** (Varredura de Vulnerabilidades, Análise de log, gerenciamento de configuração, monitoramento de rede, análise de código-fonte, pentests ou testes de penetração, identificação e análise de vulnerabilidades, auditoria de conformidade, ferramentas de forense digital, entre outras) são softwares e ferramentas especializados para gerar amostras, importar dados, sumarizar e testar os controles, avaliar conteúdos ,arquivos, parâmetros, condições e processos.
- **Simulações passo a passo:** utilizam as informações do sistema para mapear e construir os passos a serem simulados em outra ferramenta a fim de chegar ao mesmo resultado do sistema.
- **Execução de controles:** submete parâmetros de teste com dados reais, sem impactar na rotina normal de processamento do sistema.
- **Metodologias para coleta de transações.**

Principais técnicas e ferramentas para auditoria de sistemas

As principais técnicas e ferramentas para auditoria de sistemas variam de acordo com os objetivos específicos da auditoria e as áreas a serem examinadas.

- **Entrevistas** nada mais são do que conversas com pessoal chave para entender práticas, desafios e necessidades. A finalidade das entrevistas é obter insights sobre as práticas diárias, conscientização em segurança e áreas de preocupação.
- **Observação direta** é a avaliação direta de processos e controles operacionais. O objetivo é verificar a implementação prática de políticas e procedimentos.
- **Revisão documental** é a avaliação de políticas, procedimentos, manuais e documentação relacionada à segurança da informação. Sua função é garantir que a organização tenha políticas adequadas e que os procedimentos estejam em conformidade com essas políticas.
- **Análise de dados** é a revisão de registros e logs para identificar padrões ou anomalias. Sua finalidade é detectar atividades incomuns e analisar tendências de segurança.
- **Ferramentas de auditoria específicas (varredura de vulnerabilidades)**, elas identificam e avaliam vulnerabilidades em sistemas, redes e aplicativos. Exemplos: Nessus, Qualys, OpenVAS.
- **Ferramentas de auditoria específicas (análise de log)**, elas examinam registros de eventos para detectar atividades incomuns ou potencialmente maliciosas. Exemplos: Splunk, ELK Stack (Elasticsearch, Logstash, Kibana), Graylog.
- **Ferramentas de auditoria específicas (gerenciamento de configuração)**, elas monitoram e garantem a conformidade das configurações do sistema com as políticas de segurança. Exemplos: Ansible, Puppet, Chef.
- **Ferramentas de auditoria específicas (monitoramento de rede)** avaliam o tráfego de rede para identificar padrões suspeitos ou atividades maliciosas. Exemplos: Wireshark, Nagios, Snort.
- **Ferramentas de auditoria específicas (análise de código-fonte)** verificam o código-fonte de aplicativos para identificar vulnerabilidades de segurança durante o desenvolvimento. Exemplos: SonarQube, Veracode, Checkmarx.

- **Ferramentas de auditoria específicas (testes de penetração ou pentest)** fazem a simulação controlada de um ataque real para identificar e explorar vulnerabilidades. Exemplos: Metasploit, Burp Suite, OWASP ZAP.
- **Ferramentas de auditoria específicas (auditoria de conformidade)** são ferramentas de automação para verificar a conformidade com requisitos específicos. Exemplos: Nessus, OpenSCAP, Lynis.
- **Ferramentas de forense digital** são usadas para coletar, analisar e preservar evidências digitais em casos de incidentes de segurança. Exemplos: EnCase, Forensic Toolkit (FTK), Autopsy.

A escolha das técnicas e ferramentas dependerá dos objetivos específicos da auditoria, do ambiente de TI da organização e dos requisitos regulatórios. Em muitos casos, uma combinação de abordagens é utilizada para garantir uma avaliação abrangente da segurança dos sistemas.

Aplicabilidade das técnicas para auditoria de sistemas

- A **revisão documental** tem aplicabilidade alta, pois a revisão documental é fundamental para compreender as políticas de segurança, procedimentos operacionais e outros documentos relacionados à segurança da informação.
- As **entrevistas** têm sua aplicabilidade alta, pois são essenciais para obter informações contextuais, compreender práticas operacionais, desafios de segurança e para validar as informações obtidas por outras técnicas.
- A **observação direta** pode ter sua aplicabilidade de média a alta, pois a observação direta é eficaz para avaliar a implementação prática de controles de segurança, especialmente no que diz respeito à segurança física e lógica.
- A **análise de dados** tem a aplicabilidade alta, pois, incluindo a revisão de registros e logs, é essencial para identificar padrões, anomalias e possíveis ameaças.
- Os **testes de penetração (pentest)** possuem a aplicabilidade alta, pois simulam ataques reais e são eficazes para identificar e corrigir vulnerabilidades de segurança.
- A **auditoria de conformidade** tem a aplicabilidade alta, pois é crucial para garantir que a organização esteja em conformidade com padrões, regulamentações e políticas de segurança.
- A **avaliação de controles de acesso** tem a aplicabilidade alta, pois é vital para garantir que apenas usuários autorizados tenham acesso aos recursos do sistema.